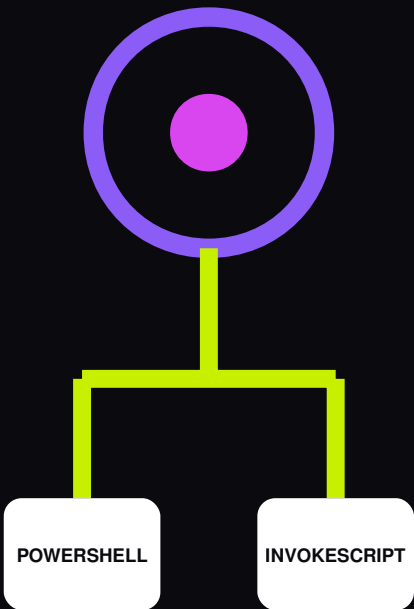


CLICKFIX POWERSHELL INVOKESCRIPT DOWNLOAD

Hunts for the source-observed PowerShell pattern that downloads script text with irm and executes it in memory through ExecutionContext.InvokeCommand.InvokeScript.

HUNTING QUERY

CONFIDENCE: MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE	STATUS
24 September 2026	Untested implementation sketch
PRIMARY PLATFORM	OPERATIONAL VALUE
Microsoft Defender XDR	9.6 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.6

Hunts for the source-observed PowerShell pattern that downloads script text with irm and executes it in memory through ExecutionContext.InvokeCommand.InvokeScript.

STATUS

Hunting query

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A result supports investigation of a high-risk download-and-execute pattern. It does not prove that the user saw a ClickFix lure, that Exvicy delivered the command, that the remote content was malicious, or that execution succeeded.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Sekoia published the Exvicy investigation on 21 September 2026 and confirmed active C2 adoption across multiple customer environments.
- 2 The observed ClickFix page instructed users to open Run and execute a PowerShell command that used irm to retrieve a remote script.
- 3 The retrieved string was executed through `$ExecutionContext.InvokeCommand.InvokeScript($a)`; the URL is mutable and is not required by the hunt.

Detection hypothesis

If an attacker executes the observed ClickFix command, endpoint telemetry should record PowerShell with both `irm` and `ExecutionContext.InvokeCommand.InvokeScript`. Distinction requires script origin, ownership, parent lineage and downstream behavior.

Unconfirmed elements

A result supports investigation of a high-risk download-and-execute pattern. It does not prove that the user saw a ClickFix lure, that Exvicy delivered the command, that the remote content was malicious, or that execution succeeded.

Logic: Campaign-specific behavioral artifact **ATT&CK:** T1059.001 / T1105



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Microsoft Defender for Endpoint process-creation telemetry in DeviceProcessEvents with full ProcessCommandLine collection.

OPTIONAL ENRICHMENT

Browser history or URL-click evidence, DNS/network records, downloaded-script response capture where lawfully available, child-process and file activity, signer/hash, user role and approved automation inventory.

Fields	Reliability	Use
Timestamp, DeviceId, DeviceName	Documented	Query or triage
FileName, FolderPath, ProcessCommandLine	Documented	Query or triage
AccountName, AccountUpn	Documented	Query or triage
ProcessUniqueld, InitiatingProcessUniqueld, ReportId	Documented	Query or triage
Full command-line population	Environment-dependent	Query or triage

Excluded

No message body, phishing-page content, inferred success, actor attribution, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
DeviceProcessEvents
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine contains "$ExecutionContext.InvokeCommand.InvokeScript"
| where ProcessCommandLine has "irm"
| project Timestamp, DeviceId, DeviceName, AccountName, AccountUpn,
    FileName, FolderPath, ProcessCommandLine,
    InitiatingProcessFileName, InitiatingProcessCommandLine,
    ProcessUniqueId, InitiatingProcessUniqueId, ReportId
| order by Timestamp desc
```

WINDOW	THRESHOLD	JOIN	KEY
None	None	None	ProcessUniqueId



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the raw process event, full command line, process identifiers, account, device and timestamp.

2

Confirm

Identify the user, workstation owner, parent process and any approved automation owner.

3

Enrich

Browser history or URL-click evidence, DNS/network records, downloaded-script response capture where lawfully available, child-process and file activity, signer/hash, user role and approved automation inventory.

4

Scope

Review adjacent browser, DNS, network, file and descendant-process evidence.

Expected benign overlap

Administrative or developer automation can intentionally fetch PowerShell source and invoke it through the PowerShell execution context. Review script origin, owner, code-signing or repository provenance, parent process, user intent and downstream behavior; do not allowlist only by URL or filename.

Response boundary

A result supports investigation of a high-risk download-and-execute pattern. It does not prove that the user saw a ClickFix lure, that Exvicy delivered the command, that the remote content was malicious, or that execution succeeded.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

1. Run the query over an agreed historical period and assign every result to an automation or workstation owner.
2. Execute a benign lab command using irm plus InvokeScript and confirm the complete command line and identifiers are retained.
3. Inspect parent process, remote URL, DNS/network events and descendant activity for each unexplained match.
4. Reject alert deployment if approved automation produces material unresolved volume; retain the query as a hunt until exclusions are ownership-based.

Decision criteria

Success: The controlled event is captured and unexplained matches are sufficiently rare and attributable for analyst review, with stable command-line visibility.

Rejection: The pattern is common in approved automation, required context is absent, or differentiation would depend on mutable domains or arbitrary thresholds.

Failure: Defender for Endpoint is absent, process telemetry is incomplete, command lines are truncated/suppressed, or the attacker changes execution method or obfuscates either anchor.

Platform	Decision	Missing evidence
Defender XDR	Hunting query	Controlled command and baseline
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Hunting query

Hunts for the source-observed PowerShell pattern that downloads script text with irm and executes it in memory through ExecutionContext.InvokeCommand.InvokeScript.

A result supports investigation of a high-risk download-and-execute pattern. It does not prove that the user saw a ClickFix lure, that Exvicy delivered the command, that the remote content was malicious, or that execution succeeded.

MITRE ATT&CK

T1059.001 / T1105

References

1. Sekoia TDR — Exvicy: A Copycat of the ErrTraffic Malware Distribution Framework — 21 Sep 2026
2. Microsoft — DeviceProcessEvents advanced hunting schema — updated 7 Aug 2026; accessed 24 Sep 2026
3. MITRE ATT&CK — T1059.001 PowerShell; T1105 Ingress Tool Transfer

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.